

What is Azure role-based access control (Azure RBAC)?

Access management for cloud resources is a critical function for any organization that is using the cloud. Azure role-based access control (Azure RBAC) helps you manage who has access to Azure resources, what they can do with those resources, and what areas they have access to.

Azure RBAC is an authorization system built on [Azure Resource Manager](#) that provides fine-grained access management to Azure resources.

This video provides a quick overview of Azure RBAC.

<https://www.youtube-nocookie.com/embed/Dzhm-garKBM> 

What can I do with Azure RBAC?

Here are some examples of what you can do with Azure RBAC:

- Allow one user to manage virtual machines in a subscription and another user to manage virtual networks
- Allow a DBA group to manage SQL databases in a subscription
- Allow a user to manage all resources in a resource group, such as virtual machines, websites, and subnets
- Allow an application to access all resources in a resource group

How Azure RBAC works

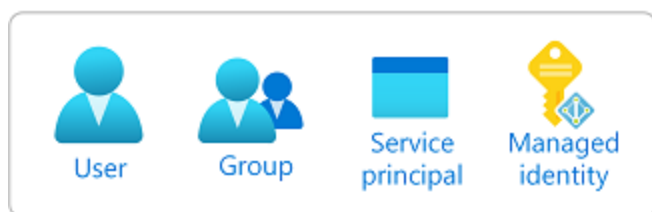
The way you control access to resources using Azure RBAC is to assign Azure roles. This is a key concept to understand – it's how permissions are enforced. A role assignment consists of three elements: security principal, role definition, and scope.

Security principal

A *security principal* is an object that represents a user, group, service principal, or managed identity that is requesting access to Azure resources. You can assign a role to any of these

security principals.

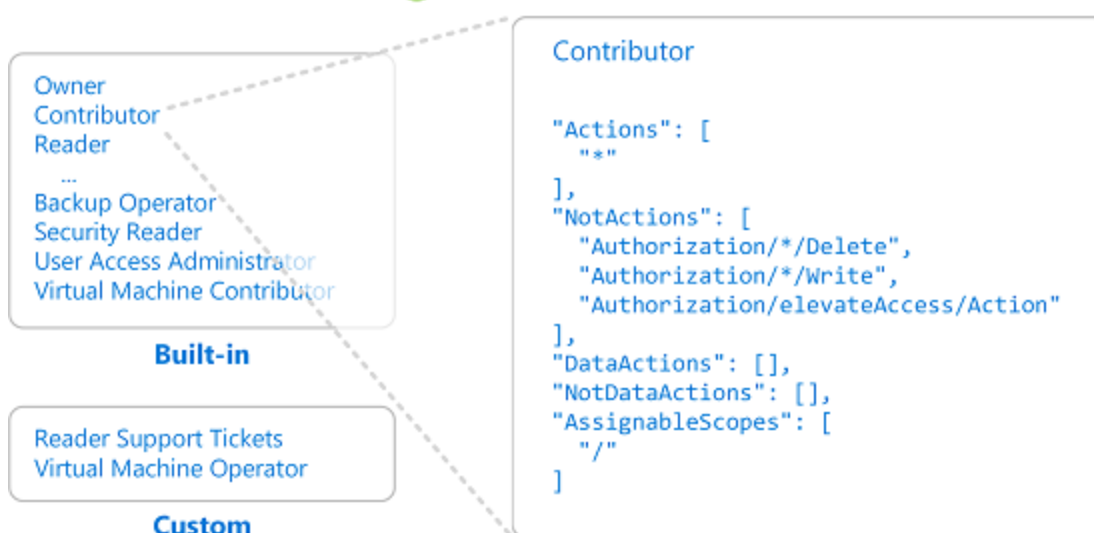
1 Security principal



Role definition

A *role definition* is a collection of permissions. It's typically just called a *role*. A role definition lists the actions that can be performed, such as read, write, and delete. Roles can be high-level, like owner, or specific, like virtual machine reader.

2 Role definition



Azure includes several [built-in roles](#) that you can use. For example, the [Virtual Machine Contributor](#) role allows a user to create and manage virtual machines. If the built-in roles don't meet the specific needs of your organization, you can create your own [Azure custom roles](#).

This video provides a quick overview of built-in roles and custom roles.

<https://www.youtube-nocookie.com/embed/I1mefHptRgo> ↗

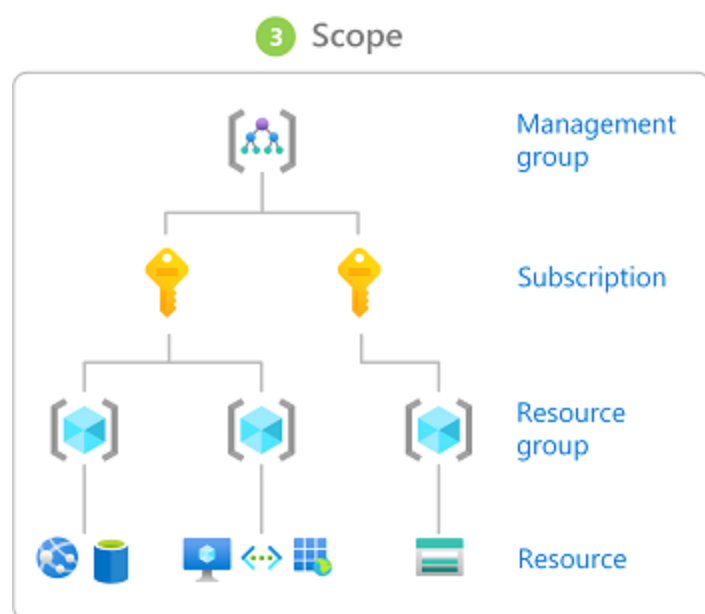
Azure has data actions that enable you to grant access to data within an object. For example, if a user has read data access to a storage account, then they can read the blobs or messages within that storage account.

For more information, see [Understand Azure role definitions](#).

Scope

Scope is the set of resources that the access applies to. When you assign a role, you can further limit the actions allowed by defining a scope. This is helpful if you want to make someone a [Website Contributor](#), but only for one resource group.

In Azure, you can specify a scope at four levels: [management group](#), subscription, [resource group](#), or resource. Scopes are structured in a parent-child relationship. You can assign roles at any of these levels of scope.

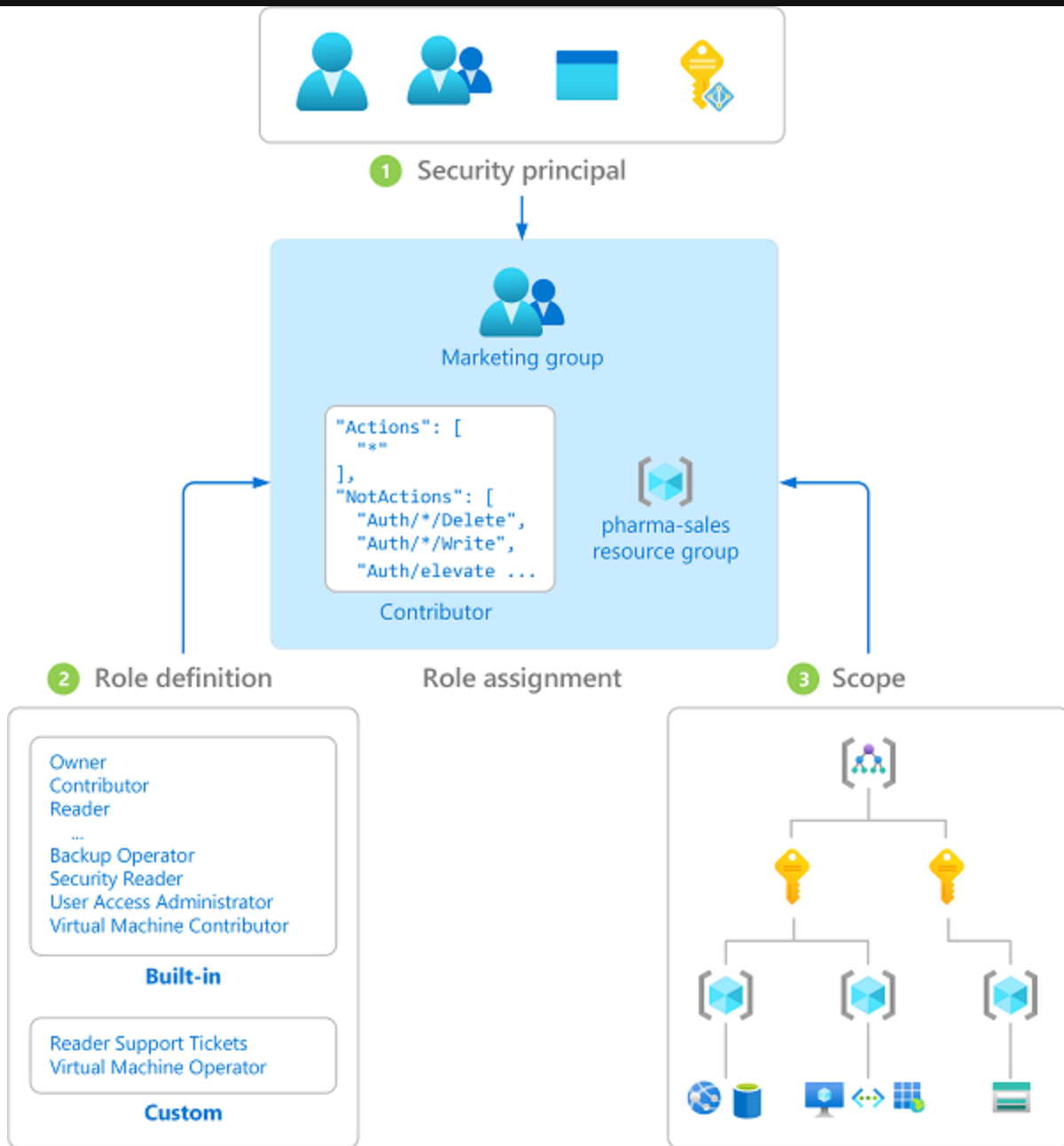


For more information about scope, see [Understand scope](#).

Role assignments

A *role assignment* is the process of attaching a role definition to a user, group, service principal, or managed identity at a particular scope for the purpose of granting access. Access is granted by creating a role assignment, and access is revoked by removing a role assignment.

The following diagram shows an example of a role assignment. In this example, the Marketing group has been assigned the [Contributor](#) role for the pharma-sales resource group. This means that users in the Marketing group can create or manage any Azure resource in the pharma-sales resource group. Marketing users don't have access to resources outside the pharma-sales resource group, unless they're part of another role assignment.



You can assign roles using the Azure portal, Azure CLI, Azure PowerShell, Azure SDKs, or REST APIs.

For more information, see [Steps to assign an Azure role](#).

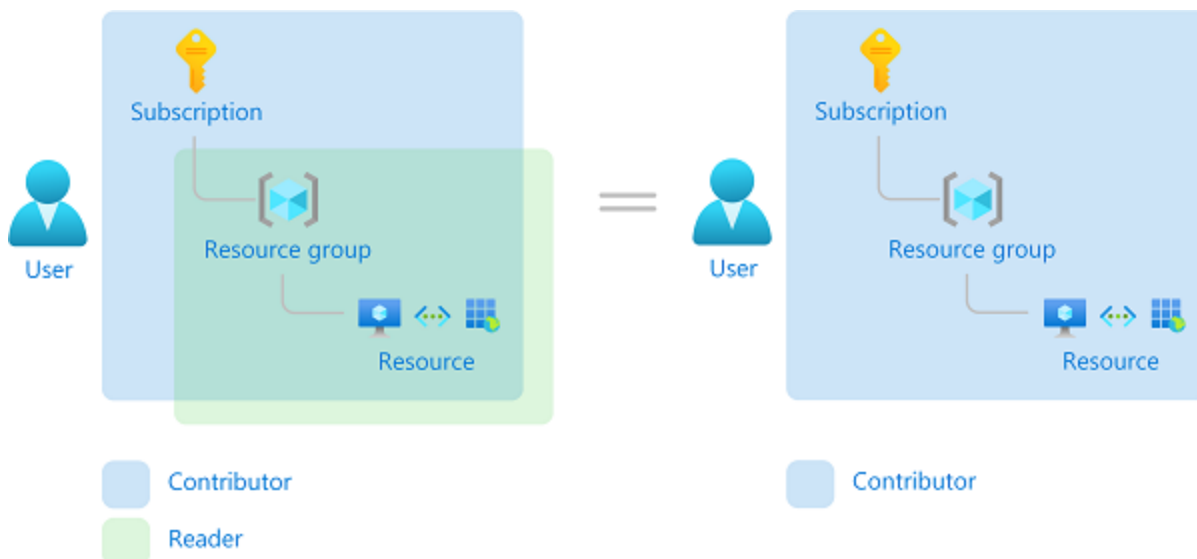
Groups

Role assignments are transitive for groups, which means that if a user is a member of a group and that group is a member of another group that has a role assignment, the user has the permissions in the role assignment.



Multiple role assignments

So what happens if you have multiple overlapping role assignments? Azure RBAC is an additive model, so your effective permissions are the sum of your role assignments. Consider the following example where a user is granted the Contributor role at the subscription scope and the Reader role on a resource group. The sum of the Contributor permissions and the Reader permissions is effectively the Contributor role for the subscription. Therefore, in this case, the Reader role assignment has no impact.



How Azure RBAC determines if a user has access to a resource

The following are the high-level steps that Azure RBAC uses to determine if you have access to a resource. These steps apply to Azure Resource Manager or data plane services integrated with Azure RBAC. This is helpful to understand if you're trying to troubleshoot an access issue.

1. A user (or service principal) acquires a token for Azure Resource Manager.

The token includes the user's group memberships (including transitive group memberships).

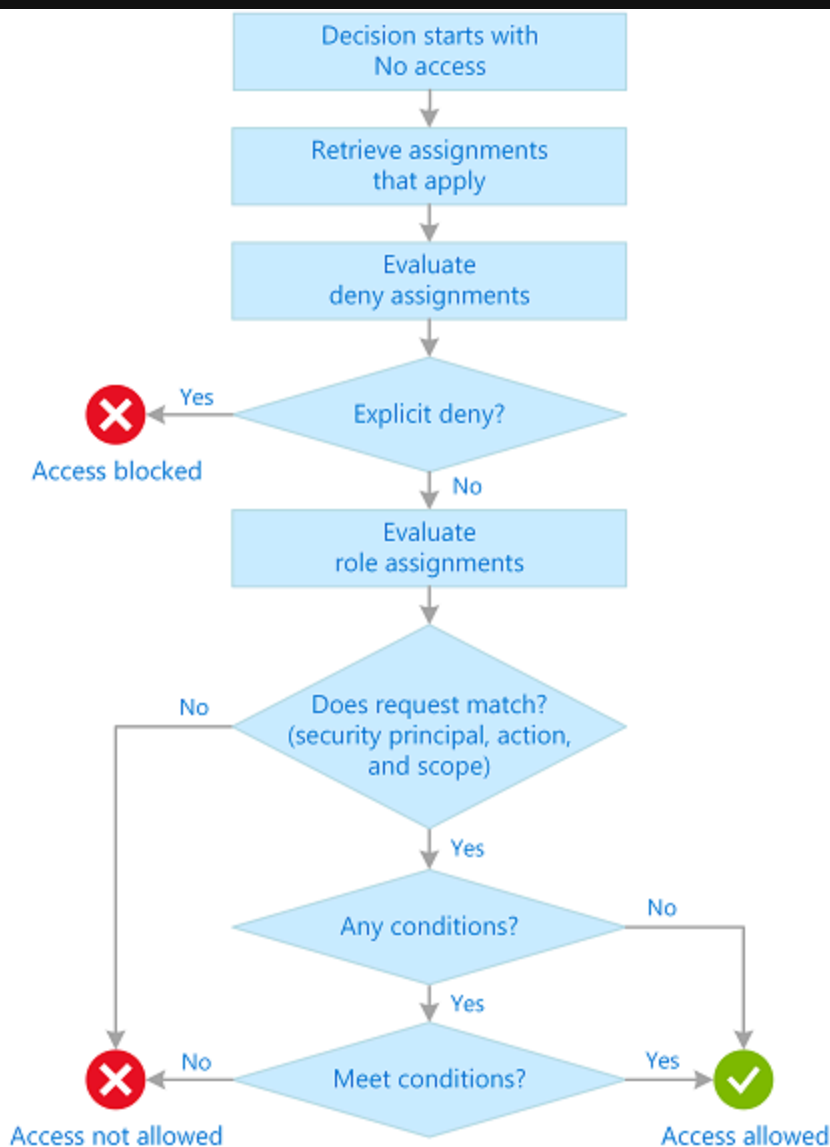
2. The user makes a REST API call to Azure Resource Manager with the token attached.
3. Azure Resource Manager retrieves all the role assignments and deny assignments that apply to the resource upon which the action is being taken.
4. If a deny assignment applies, access is blocked. Otherwise, evaluation continues.
5. Azure Resource Manager narrows the role assignments that apply to this user or their group and determines what roles the user has for this resource.
6. Azure Resource Manager determines if the action in the API call is included in the roles the user has for this resource. If the roles include `Actions` that have a wildcard (*), the effective permissions are computed by subtracting the `NotActions` from the allowed `Actions`. Similarly, the same subtraction is done for any data actions.

`Actions - NotActions = Effective management permissions`

`DataActions - NotDataActions = Effective data permissions`

7. If the user doesn't have a role with the action at the requested scope, access isn't allowed. Otherwise, any conditions are evaluated.
8. If the role assignment includes conditions, they're evaluated. Otherwise access is allowed.
9. If conditions are met, access is allowed. Otherwise access isn't allowed.

The following diagram is a summary of the evaluation logic.



Where is Azure RBAC data stored?

Role definitions, role assignments, and deny assignments are stored globally to ensure that you have access to your resources regardless of the region you created the resource.

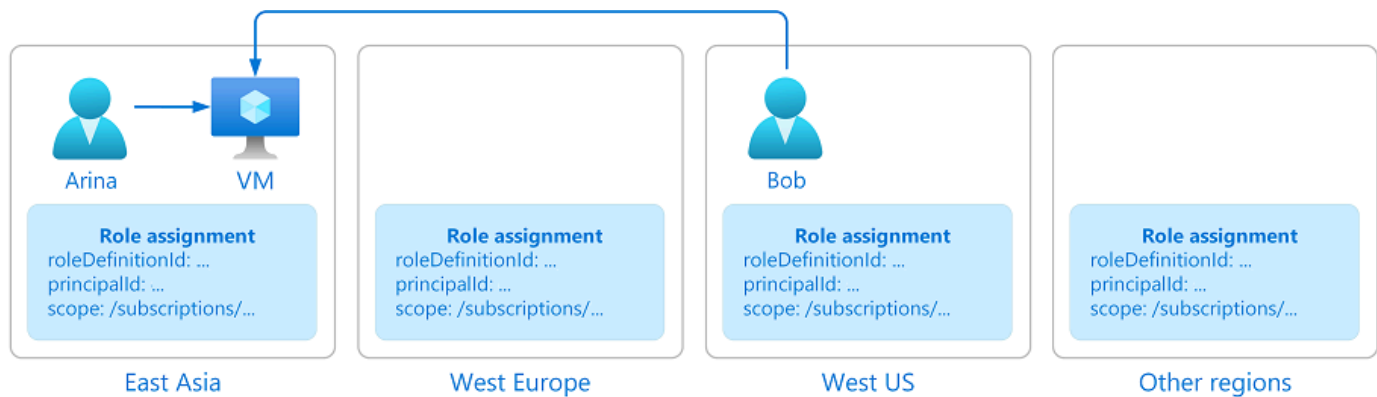
When a role assignment or any other Azure RBAC data is deleted, the data is globally deleted. Principals that had access to a resource via Azure RBAC data will lose their access.

Why is Azure RBAC data global?

Azure RBAC data is global to ensure that customers can timely access resources regardless from where they're accessing. Azure RBAC is enforced by Azure Resource Manager, which has a global endpoint and requests are routed to the nearest region for speed and resilience. Therefore, Azure

RBAC must be enforced in all regions and the data is replicated to all regions. For more information, see [Resiliency of Azure Resource Manager](#).

Consider the following example. Arina creates a virtual machine in East Asia. Bob, who is a member of Arina's team, works in the United States. Bob needs to access the virtual machine that was created in East Asia. To grant Bob timely access to the virtual machine, Azure needs to globally replicate the role assignment that grants Bob access to the virtual machine from anywhere Bob is.



License requirements

Using this feature is free and included in your Azure subscription.

Next steps

- [Assign Azure roles using the Azure portal](#)
- [Understand the different roles](#)
- [Cloud Adoption Framework: Resource access management in Azure](#)

Last updated on 03/12/2024